SECCIÓN 4.6

Comunicación con el exterior y posibles señales de C2

Temas de esta sección:

- Qué es C2 y por qué una amenaza necesita comunicarse
- C2 no siempre usa puertos raros: HTTPS, DNS, servicios legítimos
- Beaconing: patrones de comunicación periódica
- Beaconing legítimo vs sospechoso
- El proceso que se conecta y el destino importan
- Dominios raros, nuevos y servicios legítimos abusados
- Conexión bloqueada no siempre cierra el caso

C2 (Command and Control) es el canal que una amenaza puede usar para comunicarse con infraestructura externa. Puede recibir instrucciones, enviar datos, descargar payloads o mantener acceso remoto.

C2 usa protocolos normales para mezclarse con tráfico legítimo:

HTTPS / 443	HTTP / 80	DNS / 53	Cloud APIs
CDNs	Servicios de almacenamiento	Mensajería (Discord, Telegram)	Repositorios (GitHub, GitLab)

⚠ **Error común:** pensar que C2 siempre usa puertos extraños. En la práctica, muchas amenazas usan HTTPS por el puerto 443 porque suele estar permitido en todas las redes.

El SOC no debe mirar solamente el puerto. Debe mirar
proceso, destino, frecuencia, volumen, horario, usuario, DNS y actividad previa.

4.6 | Beaconing: legítimo vs sospechoso

Beaconing es comunicación periódica repetitiva. Puede ser legítimo o sospechoso según el contexto:

BEACONING LEGÍTIMO

```
Host: IT-ADM-02
Process: edr_agent.exe
Path: C:\Program Files\SecurityVendor\
Destination: console.securityvendor.com
Frequency: Every 60 seconds
Signed: Yes
Deployment: Approved
```

- Proceso conocido y firmado
- Ruta en Program Files
- Destino de proveedor de seguridad
- Despliegue documentado y aprobado

BEACONING SOSPECHOSO

```
Host: USER-LAP-088
Process: update.exe
Path: C:\Users\Public\
Destination: cdn-health-check.net
Frequency: Every 60 seconds
Signed: No  |  Created: Today
Parent Process: powershell.exe
```

- Proceso sin firma
- Ruta pública de usuario
- Destino desconocido y nuevo
- Proceso padre: PowerShell
- Primera vez observado hoy

4.6 | La escalera de sospecha: proceso + destino + secuencia

El proceso que genera la conexión y la secuencia previa son los factores más discriminantes:

`chrome.exe → outlook.office.com:443`	**ESPERADO**
`powershell.exe → raw.githubusercontent.com:443`	**ANÁLISIS**
`WINWORD.EXE → powershell.exe → unknown-domain.com:443`	**SOSPECHOSO**
`WINWORD.EXE → PS → descarga update.exe → update.exe beaconing 60s`	**CRÍTICO**

C2 es una hipótesis que necesita evidencia: proceso, ruta, firma, destino, frecuencia, persistencia, actividad previa y otros hosts. No se confirma solo por una conexión sospechosa.

No todo dominio sospechoso tiene mala reputación. A veces el C2 usa infraestructura legítima:

Señales de dominio sospechoso

- First seen: hoy o hace pocos días (dominio nuevo)
- DGA: nombre aleatorio tipo 'akd92xhfp-check.net'
- Sin historial de uso en el entorno
- Reputación baja o sin datos en Threat Intel
- Muchos NXDOMAIN de subdominos distintos (posible DGA)
- Subdominios muy largos con datos codificados (DNS tunneling)

Servicios legítimos abusados para C2

- GitHub / GitLab: payload en repositorio público
- Google Drive / OneDrive: instrucciones en archivo compartido
- Discord / Telegram: bot recibe comandos
- Pastebin / Hastebin: configuración descargada
- Slack / Teams webhooks: exfiltración de datos

⚠ El destino es legítimo pero el comportamiento del proceso no lo es

Tip: un proceso no firmado que accede a github.com cada 60 segundos desde AppData requiere el mismo análisis que si accediera a un dominio desconocido.

Un bloqueo del firewall o proxy reduce el riesgo inmediato, pero no necesariamente cierra el análisis:

Cuándo el bloqueo SÍ puede cerrar

- Alerta generada por reputación conocida (TI feed)
- El proceso que conectó es conocido y firmado
- No hay actividad sospechosa previa en el host
- El dominio es conocido como scanner automático
- No hay persistencia ni otros indicadores
- La conexión fue un evento aislado sin patrón

Cuándo el bloqueo NO cierra el caso

- Existe una cadena previa: Office → PS → intento de C2
- El proceso que intentó conectar está en ruta sospechosa
- Hay persistencia ya instalada que puede reconectar
- El mismo binario intenta múltiples dominios
- Hay otros hosts con el mismo indicador
- El binario no tiene firma y fue creado hoy

Si hay ejecución previa + persistencia + intento de C2 bloqueado → escalar. El bloqueo evitó la conexión, no la amenaza.